Parul® University
Vadodara, Gujarat

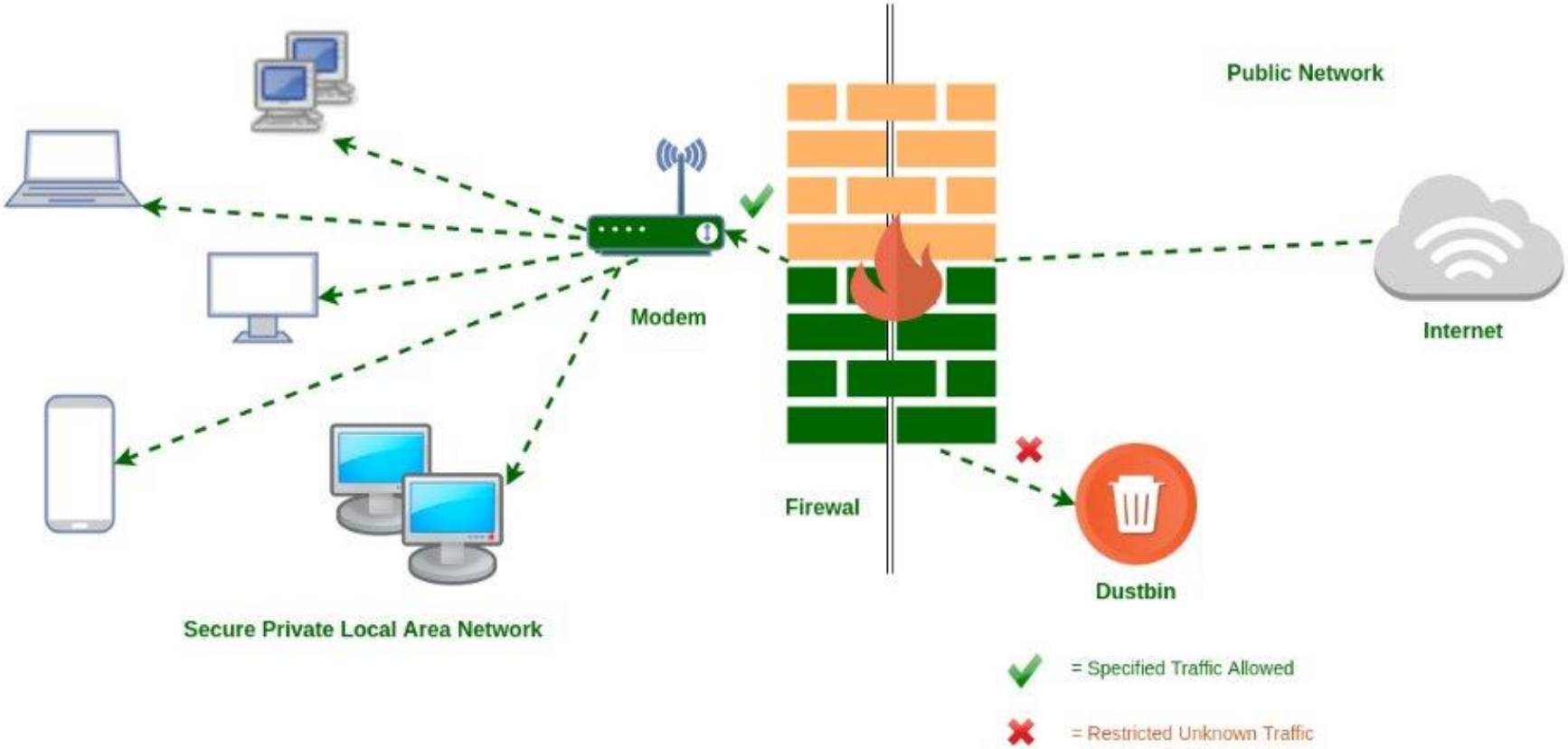
NAAC GRADE A++

Introduction of Cyber Crime Investigation

Shraddha Gaur
Department of CSE (Cyber Security)
PIET, Parul University

What is a firewall?

A firewall is a network security device that monitors and filters incoming and outgoing network traffic in accordance with previously established security policies in an organization. A firewall, at its most basic, is a barrier that sits between a private internal network and the public Internet. The primary function of a firewall is to keep dangerous traffic out while allowing non-threatening traffic in.


Public Network
Modem
Internet
Firewal
Dustbin
Secure Private Local Area Network
= Specified Traffic Allowed
= Restricted Unknown Traffic

Types of Firewalls

- Firewalls are classified as either software or hardware firewalls, depending on their structure. Each type of firewall serves a distinct purpose while providing the same functionality. However, having both is recommended for maximum protection.
- A hardware firewall is a physical piece of equipment that connects a computer network to a gateway. Consider a broadband router as an example. An Appliance Firewall is another name for a hardware firewall.
- A software firewall, on the other hand, is a simple program that is installed on a computer and operates via port numbers and other installed software. This type of firewall is also known as a Host Firewall.

Contd..

- Furthermore, there are numerous other types of firewalls based on their features and level of security. Firewall techniques that can be implemented as software or hardware include the following:

- Packet-filtering Firewalls
- Circuit-level Gateways
- Cloud Firewalls
- Unified Threat Management (UTM) Firewalls

What is Packet Filtering Firewall?

A packet filtering firewall is a network security feature that regulates the flow of incoming and outgoing network data. Each packet containing user data and control information is examined and tested by the firewall using a set of pre-defined rules. If the packet passes the test, the firewall allows it to proceed to its destination. Those who fail the test are disqualified. Firewalls inspect packets by looking at rule sets, protocols, ports, and destination addresses.

How does Packet Filtering Firewall work?

- Packets are structured data units. Because they divide communications into small bits and transport them independently across the network, these networks are fault-tolerant.
- In order to display accurate information, packages are reordered after passing through the firewall and arriving at their destination.
- Packet switching, when done correctly, increases network channel capacity and decreases transmission delay and communication efficiency. Packets include two essential components:
- Data is directed to the correct location using packet headers. They include internet protocol (IP) elements, addressing, and any other data needed to deliver packets to their destination.
- The user data contained within the packet is referred to as the payload. This is the data that is trying to get somewhere.

Packet filtering firewalls allow or deny network packets based on the following criteria:

- The source IP address is where the packet is being sent from.
- The packet's address is the destination IP address.
- Protocols: Protocols include data transfer protocols such as session and application protocols (TCP, UDP, ICMP).
- Ports include source and destination ports, as well as ICMP types and codes.
- Flags include TCP header flags such as whether the packet is a connect request.
- The physical interface (NIC) that the packet is passing through (incoming or outgoing).

What Are the Various Types of Packet Filtering Firewalls?

There are four types of packet filtering:

- Dynamic packet filtering
- Static packet filtering
- Stateless packet filtering
- Stateful packet filtering

Example of Packet Filtering Firewalls

Packet filters examine each TCP/IP packet, looking at the source and destination IP and port addresses. You can create rules that allow only known and established IP addresses while blocking all unknown or unknown IP addresses.

Denying outsiders access to port 80, for example, would prevent all outside access to the HTTP server, because most HTTP servers run on port 80. You can also configure your firewall to allow only packets intended for your mail or web server while rejecting all others.

Benefits of Packet Filtering Firewalls

Benefits of Packet Filtering Firewalls

- Efficiency
- Transparency
- Cost Effective
- Ease of Use

- Efficiency

One of the prominent advantages of packet filtering firewalls is their efficiency. Routers typically operate at high speeds, accepting and rejecting packets as quickly as possible based on their destinations, source ports, and addresses. As the filter determines the destination and legitimacy of inbound and outbound packets, they are frequently held for only a few milliseconds. The performance overheads of most other firewall techniques are higher than those of packet filtering firewalls.

- Transparency

Another benefit is transparency. While users are aware when a firewall rejects a packet, packet filters typically operate quickly and quietly, obstructing user functionality. Other methods require users to configure firewalls manually for specific clients or servers.

- Cost Effective
- Packet filtering is extremely cost-effective because only one filtering router is required to secure the internal network. Many common hardware and software routing devices include packet filtering. Furthermore, because most website routers now support packet filtering, this is the most cost-effective strategy.
- Ease of Use
- Packet filtering is an appealing option due to its low cost and ease of use. A single screening router can defend an entire network using this security strategy. Because they will not notice packet transfer unless it is rejected, users do not need much information, training, or assistance to use firewalls.

What are the drawbacks of using a Packet Filtering firewall?

Drawbacks of Packet Filtering firewall

- Less Secure
- Lack of Logging Capabilities
- Stateless

- Less Secure:
- The primary disadvantage of packet filtering is that it is based on IP address and port number rather than context or application information. As a result, they are regarded as insecure. This is because they will forward any traffic that comes through an authorized IP/port. Because the packet filter does not inspect the entire packet, a malicious command can be inserted into unnoticed headers or the payload itself.
- Lack of Logging Capabilities:
- If the packet filter lacks logging capabilities, it can pose a problem for a company that must meet compliance and reporting requirements.

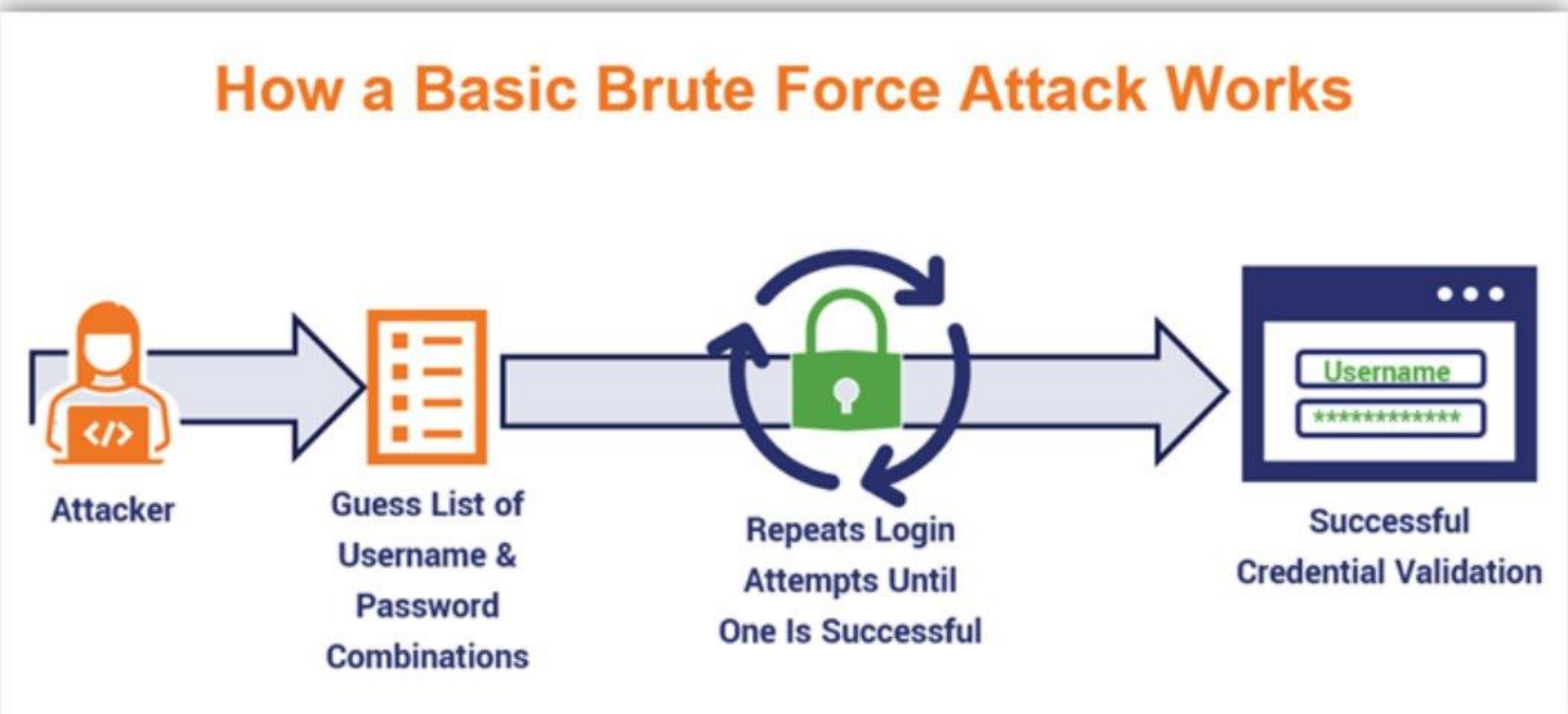
- Stateless:
- Another significant limitation of packet filtering is that it is fundamentally stateless, which means that it monitors each packet independently, regardless of the established connection or previous packets that have passed through it. As a result, the ability of firewalls to protect against severe threats and attacks is quite limited.

ACCESS GRANTED
USERNAME :
admin
PASSWORD :
****

Password cracking

- Password cracking is the process of recovering passwords from data that has been stored in or transmitted by a computer system in scrambled form. A common approach (brute-force attack) is to repeatedly try guesses for the password and to check them against an available cryptographic hash of the password. Another type of approach is password spraying, which is often automated and occurs slowly over time to remain undetected, using a list of common passwords.

- The purpose of password cracking might be to help a user recover a forgotten password (because installing an entirely new password would involve System Administration privileges), to gain unauthorized access to a system, or to act as a preventive measure whereby system administrators check for easily crackable passwords. On a file-by-file basis, password cracking is utilized to gain access to digital evidence to which a judge has allowed access, when a particular file's permissions restricted.


How a Basic Brute Force Attack Works
Attacker
Guess List of Username & Password Combinations
Repeats Login Attempts Until One Is Successful
Username
****
Successful Credential Validation

- Brute-force attack: This is the most basic and straightforward method of password cracking. It involves trying every possible combination of characters until the correct password is found. This method can be very time-consuming, but it is also very effective for cracking short and weak passwords.
- Dictionary attack: This method uses a dictionary of common words and phrases to try to guess the password. This method is more effective than brute-force attacks for cracking longer passwords, as it is more likely that the password will be a word or phrase from the dictionary.
- Rainbow table attack: This method uses a precomputed table of hashes to quickly crack passwords. Rainbow tables are created by taking a list of common passwords and hashing them with a one-way function. When a password is cracked, its hash is compared to the hashes in the rainbow table. If a match is found, the password is immediately known.

- Phishing attack: This method tries to trick the user into revealing their password. Phishing attacks often involve sending emails or creating fake websites that look like they are from a legitimate source, such as a bank or credit card company. The emails or websites will ask the user to enter their login information, which is then collected by the attacker.
- Malware attack: This method uses malware to steal passwords from the user's computer. Malware can be installed on the computer through a variety of ways, such as clicking on a malicious link or opening an infected attachment. Once the malware is installed, it can steal passwords from the user's web browser, email client, or other software.

- John the Ripper: This is a popular password cracking tool that uses a variety of methods to attack passwords, including brute force, dictionary attacks, and rainbow table attacks.
- Hashcat: This is another popular password cracking tool that is similar to John the Ripper.
- Hydra: This is a tool that can be used to brute-force login attempts against a variety of services, including SSH, FTP, and HTTP.
- Medusa: This is a tool that can be used to brute-force login attempts against Microsoft Active Directory.

Keyloggers

- Keyloggers are specifically designed to record every keystroke you make on your keyboard. This information can then be used to steal your passwords, credit card numbers, and other sensitive information. Keyloggers can be software-based, hardware-based, or even firmware-based.
- First key-logger was invented in 1970's and was a hardware key logger and first software key-logger was developed in 1983.

1. Software key-loggers : Software key-loggers are the computer programs which are developed to steal password from the victims computer. However key loggers are used in IT organizations to troubleshoot technical problems with computers and business networks. Also Microsoft windows 10 also has key-logger installed in it.

- JavaScript based key logger – It is a malicious script which is installed into a web page, and listens for key to press such as oneKeyUp(). These scripts can be sent by various methods, like sharing through social media, sending as a mail file, or RAT file.
- Form Based Key loggers – These are key-loggers which activates when a person fills a form online and when click the button submit all the data or the words written is sent via file on a computer. Some key-loggers works as a API in running application it looks like a simple application and whenever a key is pressed it records it.

2. Hardware Key-loggers : These are not dependent on any software as these are hardware key-loggers. keyboard hardware is a circuit which is attached in a keyboard itself that whenever the key of that keyboard pressed it gets recorded.

- USB keylogger – There are USB connector key-loggers which must be connected to a computer and steals the data. Also some circuits are built into a keyboard so no external wire i used or shows on the keyboard.
- Smartphone sensors – Some cool android tricks are also used as key loggers such as android accelerometer sensor which when placed near to the keyboard can sense the vibrations and the graph then used to convert it to sentences, this technique accuracy is about 80%. Now a days crackers are using keystroke logging Trojan, it is a malware which is sent to a victims computer to steal the data and login details.

So key-loggers are the software malware or a hardware which is used to steal , or snatch our login details, credentials , bank information and many more. Some keylogger application used in 2020 are:

1. Kidlogger
2. Best Free Keylogger
3. Windows Keylogger
4. Refog Personal Monitor
5. All In One Keylogger

Spyware

- Spyware is malicious software that enters a user's computer, gathers data from the device and user, and sends it to third parties without their consent.

Types of Spyware

- Adware: This sits on a device and monitors users' activity then sells their data to advertisers and malicious actors or serves up malicious ads.
- Infostealer: This is a type of spyware that collects information from devices. It scans them for specific data and instant messaging conversations.
- Keyloggers: Also known as keystroke loggers, keyloggers are a type of infostealer spyware. They record the keystrokes that a user makes on their infected device, then save the data into an encrypted log file. This spyware method collects all of the information that the user types into their devices, such as email data, passwords, text messages, and usernames.
- Rootkits: These enable attackers to deeply infiltrate devices by exploiting security vulnerabilities or logging into machines as an administrator. Rootkits are often difficult and even impossible to detect.

- Red Shell: This spyware installs itself onto a device while a user is installing specific PC games, then tracks their online activity. It is generally used by developers to enhance their games and improve their marketing campaigns.
- System monitors: These also track user activity on their computer, capturing information like emails sent, social media and other sites visited, and keystrokes.
- Tracking cookies: Tracking cookies are dropped onto a device by a website and then used to follow the user's online activity.
- Trojan Horse Virus: This brand of spyware enters a device through Trojan malware, which is responsible for delivering the spyware program.

What Does Spyware Do?

- Step 1—Infiltrate: Spyware is installed onto a device through the use of an application installation package, a malicious website, or as a file attachment.
- Step 2—Monitor and capture: Once installed, the spyware gets to work following the user around the internet, capturing the data they use, and stealing their credentials, login information, and passwords. It does this through screen captures, keystroke technology, and tracking codes.
- Step 3—Send or sell: With data and information captured, the attacker will either use the data amassed or sell it to a third party. If they use the data, they could take the user credentials to spoof their identity or use them as part of a larger cyberattack on a business. If they sell, they could use the data for a profit with data organizations, other hackers, or put it on the dark web.

How to Tell if You Have Spyware

Despite spyware being designed to go undetected, there are several telltale signs that could be indicators of a device being infiltrated. These include:

- Negative hardware performance, such as:
- A device running slower than usual
- Devices suffering frequent crashes and freezes
- A drop in application or browser performance, such as:

- Pop-up ads repeatedly appearing in browsers
- Unusual error messages
- Unexpected browser changes
- New icons appearing in the taskbar
- Browser searches redirecting to new search engines

Spyware Protection

- Cookie consent: It can be easy for users to simply click "accept" on the cookie consent pop-ups that appear on nearly every website they visit. However, they need to be careful about issuing their consent every time and only accept cookies from websites they trust.
- Browser extensions: Users can also install anti-tracking extensions that prevent the relentless online tracking of their activity on web browsers. These extensions can block activity tracking by both reputable sources and malicious actors, keeping users’ data private when they access the internet.

- Security updates: Updating software with the latest versions is vital to preventing spyware and other types of malware. Spyware typically makes its way onto devices through gaps in code or vulnerabilities in operating systems. So it is important to constantly patch potential issues and fix vulnerabilities immediately.
- Avoid free software: It can be appealing to download free software, but doing so can have costly ramifications for users and their organizations. The free software may be insecure and the creator can make a profit from users' data.
- Use secure networks: Unsecured Wi-Fi networks are an easy resource for hackers to breach devices. Avoid using free Wi-Fi networks, and only connect to trusted, secure networks.

Viruses: The Parasitic Invaders

- Viruses are malicious programs that attach themselves to legitimate files, such as executable programs or documents. When the host file is opened or executed, the virus code is activated, replicating itself and spreading to other files or systems. Viruses often exploit vulnerabilities in software or operating systems to gain access and propagate.

Key Characteristics of Viruses:

- They require a host file to attach themselves to and execute.
- They replicate themselves, creating copies that can infect other files or systems.
- They can cause various types of damage, including data corruption, file deletion, and system performance degradation.
- They can spread through various means, such as email attachments, removable drives, and network connections.

Worms: The Self-Propagating Threats

Worms, on the other hand, are self-replicating programs that can spread independently without the need for a host file. They typically exploit vulnerabilities in networks or operating systems to propagate, often at an alarming rate. Worms can consume significant bandwidth and resources, causing network congestion and system slowdowns.

Key Characteristics of Worms:

- They are self-replicating and can spread without a host file.
- They exploit vulnerabilities in networks or operating systems to propagate.
- They can cause network congestion, system slowdowns, and resource depletion.
- They can spread rapidly, infecting many systems in a short period.

Feature	Virus	Worm
Attachment to host file	Required	Not required
Replication mechanism	Replicates through host file execution	Replicates independently
Propagation method	Spreads through host files, email attachments, removable drives, network connections	Spreads through network vulnerabilities
Primary damage	Data corruption, file deletion, system performance degradation	Network congestion, system slowdowns, resource depletion
Spread rate	Slower, typically limited to the host file's reach	Faster, can spread rapidly through networks

Protecting Against Viruses and Worms:

- Regular software updates: Installing the latest security patches and updates promptly is crucial to fix vulnerabilities that attackers could exploit.
- Antivirus and anti-malware software: Employing reputable antivirus and anti-malware software that can detect, block, and remove malicious programs is essential.
- Firewalls: Implementing firewalls to control network traffic and block unauthorized access can help prevent worms from infiltrating systems.
- User education: Educating users about safe computing practices, including avoiding suspicious links, attachments, and downloads, can significantly reduce the risk of infection.

- Regular backups: Maintaining regular backups of critical data allows for recovery in case of an attack.
- Network segmentation: Segmenting networks into smaller, isolated zones can limit the spread of worms in case of an infection.
- Vulnerability scanning: Regularly scanning systems and networks for vulnerabilities can identify and address potential entry points for attacks.
- Incident response plan: Having an incident response plan in place ensures a coordinated and effective approach to handling security breaches.

Trojans: Disguised Threats

Trojans are malware programs that disguise themselves as legitimate software or files. They often appear harmless, enticing users to open or execute them. Once activated, Trojans can perform various malicious actions, including:

- Stealing sensitive data, such as passwords, credit card numbers, and personal information
- Installing additional malware onto the system
- Disrupting or disabling system functions
- Spying on user activity and monitoring keystrokes

Backdoors: Hidden Passages

- Backdoors are hidden access points within a computer system that allow unauthorized individuals to remotely control or access the system. They can be created by attackers exploiting vulnerabilities in software or hardware, or they can be intentionally installed by insiders. Once established, backdoors can be used for various malicious purposes, such as:

- Stealing data and resources from the compromised system
- Installing additional malware or launching cyberattacks from the system
- Launching surveillance operations to monitor user activity
- Creating a botnet, a network of compromised systems controlled by the attacker

Feature	Trojan	Backdoor
Purpose	Disguise as legitimate software to gain unauthorized access	Create hidden access points for remote control
Installation	Typically through user interaction (opening or executing a file)	Can be installed through vulnerabilities or by insiders
Function	Steals data, disrupts system functions, spies on user activity	Provides remote access and control, installs malware, launches attacks

Common Infection Vectors:

- Email attachments: Trojans and backdoors can be embedded in email attachments, tricking users into opening them.
- Malicious websites: Clicking on links or downloading files from suspicious websites can lead to infections.
- Removable media: Infected USB drives or other removable media can transfer malware to a computer.
- Social engineering: Attackers may use social engineering tactics, such as phishing emails or fake websites, to deceive users into revealing sensitive information or installing malware.

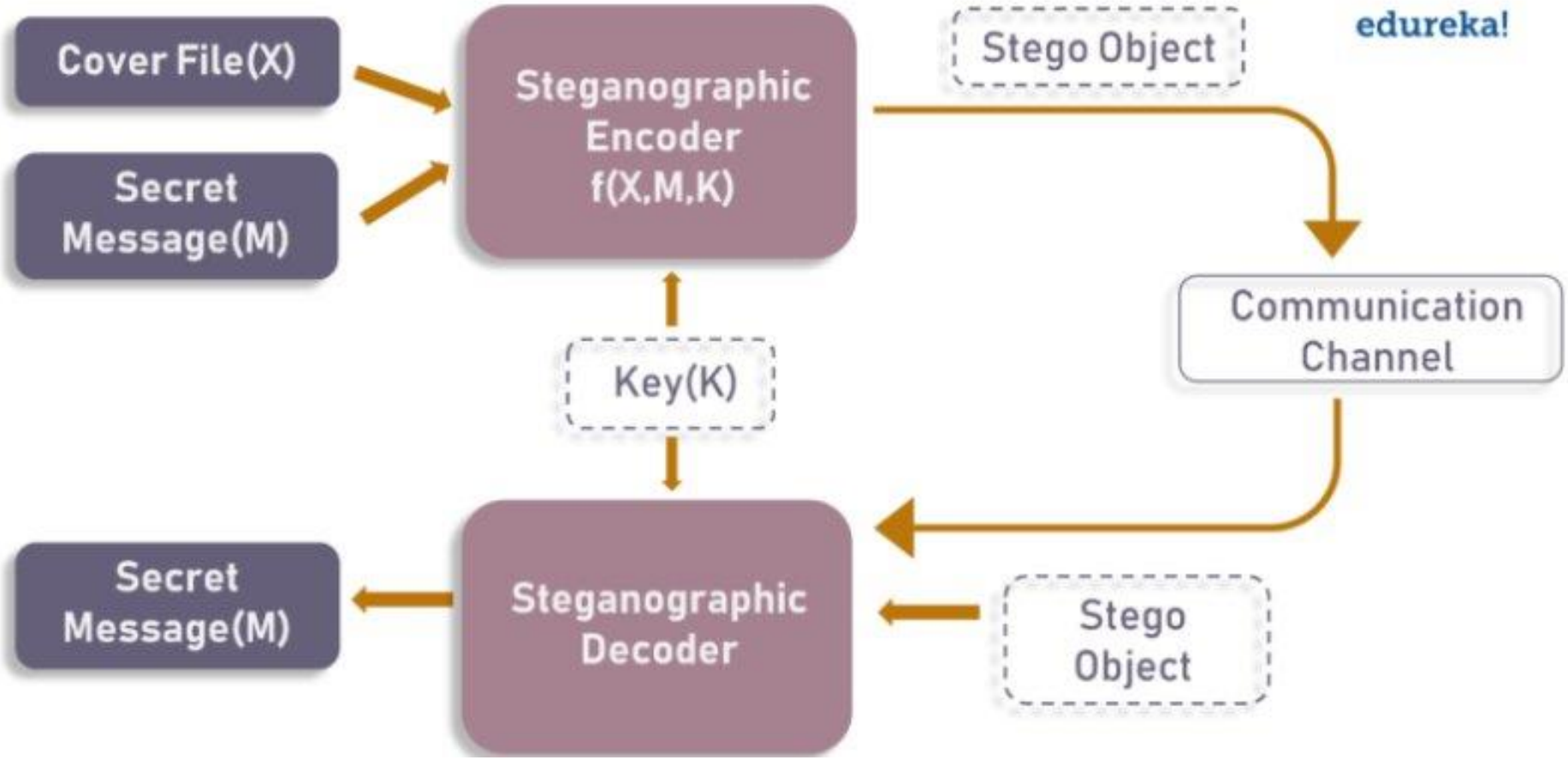
Prevention and Protection:

- Exercise caution when opening attachments or downloading files from unknown sources.
- Keep software and operating systems up to date to patch vulnerabilities.
- Install reputable antivirus and anti-malware software and keep it updated.
- Be wary of suspicious links or websites in emails and online messages.
- Educate users about cybersecurity threats and safe computing practices.
- Implement strong passwords and multi-factor authentication (MFA).
- Regularly scan systems and networks for vulnerabilities.
- Have a robust incident response plan in place to handle security breaches.

Steganography

What is Steganography?

- Steganography is the art and science of embedding secret messages in a cover message in such a way that no one, apart from the sender and intended recipient, suspects the existence of the message.
- Steganography is the practice of concealing a secret message behind a normal message. It stems from two Greek words, which are steganos, means covered and graphia, means writing. Steganography is an ancient practice, being practiced in various forms for thousands of years to keep communications private.


Cover File(X)
Secret Message(M)
Steganographic Encoder f(X,M,K)
Stego Object
edureka!
Communication Channel
Key(K)
Secret Message(M)
Steganographic Decoder
Stego Object

Historical Background

- The first use of steganography can be traced back to 440 BC when ancient Greece, people wrote messages on wood and covered it with wax, that acted as a covering medium.
- Romans used various forms of Invisible Inks, to decipher those hidden messages light or heat were used.
- During World War II the Germans introduced microdots, which were complete documents, pictures, and plans reduced in size to the size of a dot and were attached to normal paperwork.
- Null Ciphers were also used to hide unencrypted secret messages in an innocent looking normal message.

How is Steganography different from Cryptography?

- Cryptography changes the information to ciphertext which cannot be understood without a decryption key. So, if someone were to intercept this encrypted message, they could easily see that some form of encryption had been applied. On the other hand, steganography does not change the format of the information, but it conceals the existence of the message.

	STEGANOGRAPHY	CRYPTOGRAPHY
Definition	It is a technique to hide the existence of communication	It's a technique to convert data into an incomprehensible form
Purpose	Keep communication secure	Provide data protection
Data Visibility	Never	Always
Data Structure	Doesn't alter the overall structure of data	Alters the overall structure of data
Key	Optional, but offers more security if used	Necessary requirement
Failure	Once the presence of a secret message is discovered, anyone can use the secret data	If you possess the decryption key, then you can figure out original message from the ciphertext

Steganography Techniques

Depending on the nature of the cover object(actual object in which secret data is embedded), steganography can be divided into five types:

- Text Steganography
- Image Steganography
- Video Steganography
- Audio Steganography
- Network Steganography

Text Steganography

- Text Steganography is hiding information inside the text files. It involves things like changing the format of existing text, changing words within a text, generating random character sequences or using context-free grammars to generate readable texts. Various techniques used to hide the data in the text are:

- Format Based Method
- Random and Statistical Generation
- Linguistic Method

Image Steganography

- Hiding the data by taking the cover object as the image is known as image steganography. In digital steganography, images are widely used cover source because there are a huge number of bits present in the digital representation of an image. There are a lot of ways to hide information inside an image. Common approaches include:
- Least Significant Bit Insertion
- Masking and Filtering
- Redundant Pattern Encoding
- Encrypt and Scatter
- Coding and Cosine Transformation

Audio steganography

- In audio steganography, the secret message is embedded into an audio signal which alters the binary sequence of the corresponding audio file. Hiding secret messages in digital sound is a much more difficult process when compared to others, such as Image Steganography. Different methods of audio steganography include:

- Least Significant Bit Encoding
- Parity Encoding
- Phase Coding
- Spread Spectrum
- This method hides the data in WAV, AU, and even MP3 sound files.

Video Steganography

- In Video Steganography you can hide kind of data into digital video format. The advantage of this type is a large amount of data can be hidden inside and the fact that it is a moving stream of images and sounds. You can think of this as the combination of Image Steganography and Audio Steganography. Two main classes of Video Steganography include:

- Embedding data in uncompressed raw video and compressing it later
- Embedding data directly into the compressed data stream

Network Steganography (Protocol Steganography)

- It is the technique of embedding information within network control protocols used in data transmission such TCP, UDP, ICMP etc. You can use steganography in some covert channels that you can find in the OSI model. For Example, you can hide information in the header of a TCP/IP packet in some fields that are optional.

- In today's digitalized world, various software tools are available for Steganography.

Best Tools to Perform Steganography

- **Stegosuite** is a free steganography tool which is written in Java. With Stegosuite you can easily hide confidential information in image files.
- **Steghide** is an open-source Steganography software that lets you hide a secret file in image or audio file.
- **Xiao Steganography** is a free software that can be used to hide data in BMP images or in WAV files.
- **SSuite Picsel** is another free portable application to hide text inside an image file but it takes a different approach when compared to other tools.
- **OpenPuff** is a professional steganographic tool where you can store files in image, audio, video or flash files

Denial-of-Service (DoS) Attacks

- A denial-of-service (DoS) attack is an attempt to make a computer resource unavailable to its intended users. This can be accomplished by overwhelming the target system with traffic, such as sending it many requests or packets. DoS attacks can be launched from a single computer or from a network of computers.

Types of DoS Attacks:

- Volume-based DoS attacks: These attacks overwhelm the target system with a large volume of traffic, such as sending it many SYN packets or HTTP requests. This can cause the target system to crash or become unresponsive.

- Protocol attacks: These attacks exploit vulnerabilities in network protocols to disrupt the target system's ability to communicate. For example, a Smurf attack exploits a vulnerability in the ICMP protocol to send large number of packets to the target system, overwhelming its resources.

- Application-layer attacks: These attacks target specific applications or services on the target system. For example, a Slowloris attack sends many slow, low-rate HTTP requests to the target system, causing it to consume excessive resources and become unresponsive.

Impact of DoS Attacks:

- DoS attacks can have a significant impact on organizations, including:
- Loss of revenue: If a website or online service is unavailable, businesses can lose revenue.
- Damage to reputation: A DoS attack can damage a company's reputation and make it difficult to attract and retain customers.
- Increased costs: Organizations may incur additional costs to mitigate DoS attacks and recover from them.

DDoS Attacks

- A distributed denial-of-service (DDoS) attack is a DoS attack that is launched from a distributed network of computers. This makes DDoS attacks more difficult to defend against than DoS attacks, as the traffic is coming from multiple sources.

DDoS Attack Methods:

- Reflector attacks: These attacks exploit vulnerabilities in network protocols to reflect traffic from large number of sources to the target system. For example, a DNS reflection attack exploits a vulnerability in the Domain Name System (DNS) protocol to send large number of UDP packets to the target system.
- Amplification attacks: These attacks exploit vulnerabilities in network protocols to amplify the amount of traffic sent to the target system. For example, a UDP fragmentation attack exploits a vulnerability in the UDP protocol to send many small UDP packets to the target system, which are then reassembled into much larger packets.
- Application-layer DDoS attacks: These attacks target specific applications or services on the target system. For example, a HTTP flood attack sends large number of HTTP requests to the target system, causing it to consume excessive resources and become unresponsive.

DDoS Attack Mitigation:

- Implementing firewalls and intrusion detection systems (IDS): These systems can help to block malicious traffic and identify suspicious activity.
- Using content delivery networks (CDNs): CDNs can help to distribute traffic and reduce the impact of DDoS attacks.
- Using DDoS mitigation services: These services can help to absorb and filter DDoS attack traffic.
- Educating employees about DDoS attacks: This can help to reduce the risk of social engineering attacks being used to launch DDoS attacks.

Types of SQL Injection Attacks

- There are several different types of SQL injection attacks, each with its own specific objectives and techniques. Some of the most common types include:
- In-band SQL injection: This type of attack sends the malicious SQL code back to the application where it is executed. The attacker can then observe the results of the attack by analyzing the application's response.
- Out-of-band SQL injection: This type of attack sends the malicious SQL code to a different server, where it is executed. The attacker can then collect the results of the attack by accessing the second server.
- Blind SQL injection: This type of attack utilizes error messages or other indirect methods to gain information from the database without directly observing the results.

Defending Against SQL Injection Attacks

- Input validation: Sanitize all user input before incorporating it into SQL queries. This includes escaping special characters and validating input against expected data types.
- Prepared statements: Use prepared statements, which bind parameters to SQL queries instead of directly embedding user input. This prevents malicious code from being injected into the query.
- Web application firewalls (WAFs): Implement WAFs to filter out malicious requests before they reach the application. WAFs can be configured to detect and block SQL injection attacks.
- Regular application updates: Keep applications up to date with the latest security patches to fix known vulnerabilities.
- Security awareness training: Educate employees about SQL injection attacks and how to avoid providing malicious input to applications.

Buffer Overflow

- Buffer overflow, also known as buffer overrun, is a common and highly exploitable vulnerability in software that occurs when a program attempts to write more data to a buffer than the buffer can hold. This can lead to data corruption, arbitrary code execution, and system compromise.

- Understanding Buffer Overflow
- When a program allocates memory for a buffer, it specifies a maximum size for the buffer. This size limit ensures that the buffer can safely store the data it is intended to hold. However, if a program attempts to write more data to the buffer than the buffer can hold, the excess data will spill over into adjacent memory locations. This can overwrite data in other variables, functions, or even the program's own code.

Types of Buffer Overflow

- Stack-based buffer overflow: This type of attack occurs when the overflowing buffer is located on the program's stack. The stack is a data structure that stores function call information and local variables. If an attacker can overflow the stack, they may be able to overwrite return addresses or local variables, leading to arbitrary code execution.

- Heap-based buffer overflow: This type of attack occurs when the overflowing buffer is located on the heap. The heap is a dynamic memory allocation space that is used to store data that is created or modified during program execution. If an attacker can overflow the heap, they may be able to corrupt data structures or execute arbitrary code.

Impact of Buffer Overflow Attacks

- Data corruption: Buffer overflow can overwrite data in other memory locations, leading to corrupted data or unpredictable program behavior.
- Denial-of-service (DoS) attacks: Attackers can trigger buffer overflows to cause programs to crash or become unresponsive, effectively denying legitimate users access to the system.
- Arbitrary code execution (ACE): In the most severe cases, attackers can exploit buffer overflow vulnerabilities to execute arbitrary code on the target system. This can give them complete control over the system and allow them to steal data, install malware, or disrupt operations.

Preventing Buffer Overflow Attacks

- Input validation: Sanitize all user input before incorporating it into buffers. This includes checking the length of input data and ensuring that it does not contain unexpected characters.
- Bounds checking: Implement bounds checking to ensure that programs do not write beyond the boundaries of buffers. This can be done using explicit checks or by using safer programming languages that automatically perform bounds checking.
- Secure coding practices: Follow secure coding practices, such as using safe coding libraries and avoiding dangerous programming constructs that are known to be vulnerable to buffer overflow attacks.
- Regular software updates: Keep software up to date with the latest security patches to fix known vulnerabilities.
- Vulnerability scanning: Regularly scan software and systems for vulnerabilities to identify and address potential buffer overflow issues.

Parul® University | NAAC GRADE A++

https://paruluniversity.ac.in/